МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ

Федеральное государственное автономное образовательное учреждение высшего образования

«Дальневосточный федеральный университет»
(ДВФУ)

ИНСТИТУТ МАТЕМАТИКИ И КОМПЬЮТЕРНЫХ ТЕХНОЛОГИЙ

Департамент математического и компьютерного моделирования

Лабораторная работа №1

по теме: «Анализ рисков информационной безопасности», вариант 10

Выполнил студент
гр. Б9123-02.03.01сцт
Избосарова Жасмина Олимжоновна

г. Владивосток
2026

Содержание

Задание 2

1 Обоснование выбора информационных активов организации 2

2 Оценка ценности информационных активов 3

3 Уязвимости системы защиты информации 4

4 Угрозы ИБ 4

5 Оценка рисков 5

6 Выводы 6

7 Литература 7

Задание

В данной работе рассматривается дизайнерская фирма (вариант 10). Задание выполняется по методичке:

1. Загрузить ГОСТ Р ИСО/МЭК ТО 27005-2010 «МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ». Часть 3 «Методы менеджмента безопасности информационных технологий».
2. Ознакомиться с Приложениями C, D и E ГОСТа.
3. Выбрать три различных информационных актива организации (см. вариант).
4. Из Приложения D ГОСТа подобрать три конкретных уязвимости системы защиты указанных информационных активов.
5. Пользуясь Приложением C ГОСТа написать три угрозы, реализация которых возможна, пока в системе не устранены названные в пункте 4 уязвимости.
6. Пользуясь одним из методов, предложенных в Приложении E ГОСТа, произвести оценку рисков информационной безопасности.
7. Оценку ценности информационного актива производить на основании возможных потерь для организации в случае реализации угрозы.

Обоснование выбора информационных активов организации

Рассматривается небольшая дизайнерская фирма, которая занимается разработкой фирменного стиля, полиграфии, веб-дизайна и рекламных материалов для заказчиков. В штате около 15 человек: дизайнеры, менеджеры проектов и бухгалтер. Для работы нужны три вещи: файлы с проектами (макеты, исходники), рабочие компьютеры дизайнеров и электронная почта для общения с клиентами. Именно эти три актива и были выбраны — они покрывают и творческую часть, и рабочий процесс, и коммуникации.

1. **Файловое хранилище проектов.** Здесь лежат все рабочие файлы: макеты в Figma/Photoshop/Illustrator, исходники логотипов, вёрстка,

шрифты. Это главный результат работы фирмы. Если файлы пропадут или утекут к конкурентам — фирма потеряет и работу, и доверие клиентов.

2. **Рабочие станции дизайнеров.** Компьютеры (обычно Mac или мощные ПК), на которых стоят лицензионные программы: Adobe Creative Cloud, Figma, CorelDRAW. На них ведётся вся работа. Поломка или заражение вирусом означает простой.

3. **Корпоративная электронная почта.** Через почту идёт переписка с заказчиками: техзадания, правки, утверждение макетов, отправка готовых файлов. Также через неё приходят договоры и счета. Взлом почты — это и утечка информации, и потеря клиентов.

Все три актива связаны друг с другом: дизайнер работает на рабочей станции, сохраняет файлы в хранилище, а результат отправляет клиенту по почте. Если что-то из этого выйдет из строя или будет скомпрометировано, пострадает вся цепочка.

Оценка ценности информационных активов

Ценность каждого актива оценивается по тому, какие потери понесёт фирма, если с ним что-то случится. Фирма небольшая, поэтому суммы не такие большие, как в банке, но для маленькой компании они ощутимы. Используется шкала от 1 до 5 по примеру 2 из Приложения Е.2.2: 1 — минимальные потери, 5 — очень серьёзные.

1. **Файловое хранилище проектов — ценность 5 (очень высокая).** Возможные потери около 1,5 млн руб.: переделка утраченных проектов, срыв сроков, штрафы по договорам, потеря клиентов из-за утечки их материалов. Это основной продукт работы фирмы. Потеря файлов — потеря всего.

2. **Рабочие станции дизайнеров — ценность 3 (средняя).** Возможные потери около 500 тыс. руб.: простой сотрудников, покупка/переустановка ПО, восстановление локальных файлов. Неприятно, но восстановить можно за несколько дней. Лицензии привязаны к аккаунтам, а не к железу.

3. **Корпоративная электронная почта — ценность 4 (высокая).** Возможные потери около 800 тыс. руб.: утечка переписки с клиентами, потеря контактов, рассылка спама от имени фирмы, репутационный ущерб. Почта — лицо компании. Взлом сильно бьёт по репутации.

Уязвимости системы защиты информации

Уязвимости взяты из Приложения D, таблица D.1. Для каждого актива подобрана та уязвимость, которая реально может встретиться в небольшой дизайнерской фирме, где обычно нет выделенного сисадмина и вопросы безопасности решаются «по ходу дела».

1. **Файловое хранилище проектов** (вид: программные средства).

   Уязвимость: отсутствие резервных копий.

   Связанная угроза: искажение данных.

2. **Рабочие станции дизайнеров** (вид: персонал).

   Уязвимость: ненадлежащее использование программных и аппаратных средств.

   Связанная угроза: ошибка в использовании.

3. **Корпоративная электронная почта** (вид: сеть).

   Уязвимость: передача паролей в открытом виде.

   Связанная угроза: перехват информации.

Уязвимости выбраны не случайно. В маленькой фирме часто нет бэкапов («да ладно, ничего не случится»), сотрудники ставят что попало на рабочие компьютеры, а пароли от почты бывают простыми или передаются в мессенджерах открытым текстом.

Угрозы ИБ

Угрозы подобраны из Приложения C, таблица C.1. «У» — умышленная угроза, «С» — случайная. Для каждой пары «уязвимость–актив» описан конкретный сценарий: что может случиться и как.

1. **Искажение данных** (случайная).

   Уязвимость: отсутствие резервных копий.

   Сценарий: дизайнер случайно удаляет папку с проектом крупного заказчика. Бэкапов нет, корзина очищена. Проект приходится делать заново, срок сорван, клиент уходит.

2. **Ошибка в использовании** (случайная).

   Уязвимость: ненадлежащее использование ПО и аппаратных средств.

   Сценарий: сотрудник скачивает «бесплатный» плагин для Photoshop с сомнительного сайта. Вместе с плагином устанавливается вредоносная программа, которая шифрует файлы на компьютере. Работа останавливается, пока комп не переустановят.

3. **Перехват информации** (умышленная).

   Уязвимость: передача паролей в открытом виде.

   Сценарий: менеджер отправляет пароль от корпоративной почты новому сотруднику в обычном сообщении в Telegram. Злоумышленник, получивший доступ к одному из аккаунтов, видит пароль и заходит в почту фирмы. Читает переписку, скачивает файлы клиентов.

Эти три сценария вполне реалистичны для небольшой фирмы. Дальше на их основе считается риск.

Оценка рисков

Используется подход из Приложения Е, пример Е.2.2: риск считается как произведение ценности актива на вероятность реализации угрозы. Формула: $R = V \times P$.

Шкала вероятности:

— 1 — очень низкая (маловероятно, нужно редкое стечение обстоятельств);

— 2 — низкая (может случиться, но нечасто);

— 3 — средняя (вполне реальный сценарий);

— 4 — высокая (скорее всего случится при текущих условиях);

— 5 — очень высокая (случается регулярно или почти неизбежно).

Расчёт рисков:

№	Актив	Уязвимость	Угроза	V	P	R	Ранг
1	Файловое хранилище проектов	Отсутствие резервных копий	Искажение данных	5	4	20	1
2	Корпоративная электронная почта	Передача паролей в открытом виде	Перехват информации	4	3	12	2
3	Рабочие станции дизайнеров	Ненадлежащее использование ПО	Ошибка в использовании	3	3	9	3

Итоговое ранжирование:

1. **Потеря файлов проектов из-за отсутствия бэкапов** — $R = 20$ (очень высокий риск).
2. **Перехват пароля и взлом корпоративной почты** — $R = 12$ (высокий риск).
3. **Заражение рабочей станции из-за скачивания сомнительного ПО** — $R = 9$ (средний риск).

Самый опасный сценарий — потеря проектных файлов ($R = 5 \times 4 = 20$). Вероятность поставлена 4, потому что в маленьких фирмах бэкапы часто не делаются вообще. На втором месте — перехват пароля от почты ($R = 4 \times 3 = 12$). На третьем — заражение рабочей станции ($R = 3 \times 3 = 9$).

Выводы

В работе были рассмотрены три информационных актива дизайнерской фирмы: файловое хранилище проектов, рабочие станции дизайнеров и корпоративная электронная почта.

Для каждого актива определена ценность от 3 до 5 по пятибалльной шкале. Самым ценным оказалось хранилище проектов — потеря файлов для дизайнерской фирмы фактически означает потерю результатов работы.

Из Приложения D подобраны три уязвимости: отсутствие бэкапов, небрежное обращение с ПО и передача паролей в открытом виде. Каждой уязвимости сопоставлена угроза из Приложения C.

По методу E.2.2 получены меры риска: 20, 12 и 9. Главный риск — потеря данных без возможности восстановления. Чтобы его снизить, нужно в первую очередь настроить автоматическое резервное копирование (хотя бы в облако). Кроме того, стоит ввести правило не передавать пароли через мессенджеры и не скачивать программы из непроверенных источников.

Литература

1. ГОСТ Р ИСО/МЭК 27005-2010 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности».

2. ГОСТ Р ИСО/МЭК 27001-2006 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования».

3. Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных».

4. Астахов А.М. Искусство управления информационными рисками. — М.: ДМК Пресс, 2010. — 312 с.